

SGSI-UNCP

Política de Seguridad en las Relaciones con Proveedores

Documento Base del Sistema de Gestión
de Seguridad de la Información

Universidad Nacional del Centro del Perú

Índice

- 1 Política de Seguridad en las Relaciones con Proveedores
 - 1.1 Objetivo
 - 1.2 Alcance
 - 1.3 Clasificación de Proveedores según Riesgo
 - 1.4 Requisitos Contractuales Mínimos
 - 1.5 Evaluación de Seguridad del Proveedor
 - 1.6 Gestión de la Cadena de Suministro
 - 1.7 Monitoreo y Control de Accesos
 - 1.8 Gestión de Cambios en Servicios de Proveedores
 - 1.9 Responsabilidades
 - 1.10 Incumplimiento del Proveedor
 - 1.11 Documentos Relacionados
 - 1.12 ***

1. Política de Seguridad en las Relaciones con Proveedores

Organización: Universidad Nacional del Centro del Perú (UNCP) **Aprobado por:** Comité de Gobierno y Transformación Digital **Norma:** ISO/IEC 27001:2022 (Controles A.5.19–A.5.23) **Alineamiento:** P-SGSI-06 (Procedimiento de Gestión de Seguridad con Proveedores), D-SGSI-04 (Metodología de Riesgos)

1.1. Objetivo

Establecer los principios y requisitos de seguridad que deben regir la relación con todos los proveedores que tengan acceso a la información, sistemas, redes o instalaciones de la UNCP, asegurando que los riesgos de la cadena de suministro sean identificados, evaluados y mitigados durante todo el ciclo de vida del servicio.

1.2. Alcance

Esta política aplica a todos los proveedores, contratistas, consultores y socios de negocio que:

- Accedan a datos institucionales (personales, académicos, financieros o de investigación).
- Presten servicios de tecnología de la información (cloud, hosting, soporte, desarrollo, conectividad).
- Ingresen físicamente a las instalaciones de la UNCP (mantenimiento, auditoría, servicios generales).
- Participen en la cadena de suministro de software o hardware institucional.
- Tengan acceso remoto a los sistemas de la UNCP (VPN, escritorio remoto, consolas de administración).

1.3. Clasificación de Proveedores según Riesgo

Nivel	Criterio	Ejemplos UNCP	Requisitos Aplicables
Crítico	Acceso a datos personales masivos o sistemas misionales	Huawei Cloud, proveedor ERP ADESA, Microsoft 365	Todos los requisitos de esta política + auditoría in situ anual
Alto	Acceso a infraestructura de red o sistemas de apoyo	ISP, proveedor de cableado estructurado, soporte SIGA	Contrato con cláusulas SGSI + SLA de seguridad + derecho a auditoría documental
Medio	Servicios generales con acceso físico a instalaciones	Limpieza, vigilancia, mantenimiento eléctrico	Acuerdo de confidencialidad + acompañamiento en instalaciones
Bajo	Bienes o servicios sin acceso a información	Proveedores de útiles de oficina, mobiliario	Sin requisitos adicionales de seguridad

1.4. Requisitos Contractuales Mínimos

Todo contrato con un proveedor de nivel Crítico o Alto debe incluir:

1. **Cláusula de Confidencialidad:** Obligación de proteger la información de la UNCP incluso después de terminado el contrato, conforme a la Ley N° 29733.
2. **Cumplimiento del SGSI:** Aceptación expresa de cumplir con las políticas de seguridad de la UNCP aplicables al servicio contratado.
3. **Acuerdo de Nivel de Servicio (SLA) de Seguridad:** Tiempos máximos de respuesta ante incidentes, disponibilidad del servicio, ventanas de mantenimiento.
4. **Derecho a Auditoría:** La UNCP se reserva el derecho de auditar los controles de seguridad del proveedor, incluyendo la solicitud de reportes SOC 2, ISO 27001 o equivalentes.
5. **Notificación de Incidentes:** El proveedor debe notificar a la UNCP cualquier incidente de seguridad que afecte sus datos en un plazo máximo de 24 horas.
6. **Portabilidad y Devolución de Datos:** Al terminar el contrato, el proveedor debe devolver todos los datos en formato interoperable y eliminar las copias en su poder, certificando dicha eliminación.

7. **Subcontratación:** El proveedor no puede subcontratar servicios críticos sin autorización previa por escrito de la UNCP.

1.5. Evaluación de Seguridad del Proveedor

1.5.1. 5.1 Evaluación Precontractual

Antes de la contratación, la OTI y el Oficial de Seguridad evaluarán:

- Madurez de seguridad del proveedor (certificaciones vigentes, políticas publicadas).
- Historial de incidentes de seguridad públicos.
- Ubicación de los datos (cumplimiento de la Ley N° 29733 sobre transferencia internacional de datos).
- Dependencia y riesgo de concentración (evitar vendor lock-in en servicios críticos).

1.5.2. 5.2 Evaluación Periódica

- **Críticos:** Revisión anual de controles + verificación de certificaciones vigentes.
- **Alto:** Revisión documental cada 2 años.
- **Medio:** Evaluación al inicio y al renovar el contrato.

1.6. Gestión de la Cadena de Suministro

La UNCP mantendrá un registro actualizado de su cadena de suministro de TI, identificando para cada servicio crítico:

- Proveedor principal y alternativos evaluados.
- Dependencias tecnológicas (plataformas, librerías, servicios embebidos).
- Plan de migración o contingencia en caso de quiebra, incumplimiento o cese del proveedor (estrategia de salida).

1.7. Monitoreo y Control de Accesos

- Todo acceso de proveedores a sistemas UNCP debe ser **nominativo, temporal y autorizado** mediante el formato **F-SGSI-01**.
- Las cuentas de proveedores deben desactivarse automáticamente al vencer el contrato o el plazo autorizado.
- Los accesos remotos de proveedores deben realizarse a través de la **VPN institucional** con MFA y registrarse en el SIEM.
- La OTI realizará revisiones trimestrales de las cuentas activas de proveedores.

1.8. Gestión de Cambios en Servicios de Proveedores

El proveedor debe notificar a la UNCP con al menos **30 días calendario** de anticipación cualquier cambio planificado que pueda afectar la seguridad del servicio, incluyendo:

- Cambios en la versión del software o plataforma.
- Migraciones de infraestructura (cambio de datacenter, región cloud).
- Cambios en el personal clave asignado al servicio.
- Actualizaciones de términos de servicio o políticas de privacidad.

La UNCP evaluará el impacto del cambio y podrá rechazarlo si introduce riesgos no aceptables.

1.9. Responsabilidades

Rol	Responsabilidad
Oficial de Seguridad	Definir requisitos de seguridad para proveedores; evaluar riesgos de la cadena de suministro.
OTI	Realizar evaluaciones precontractuales y periódicas; gestionar accesos de proveedores.
Oficina de Abastecimiento	Incluir cláusulas de seguridad en los contratos; gestionar el proceso de contratación.
Asesoría Jurídica	Revisar y aprobar las cláusulas contractuales de seguridad y protección de datos.
Dueño del Servicio	Validar que el proveedor cumple los requisitos operativos y de seguridad del área usuaria.

1.10. Incumplimiento del Proveedor

El incumplimiento de los requisitos de seguridad por parte de un proveedor será gestionado según la criticidad:

Situación	Acción
Incumplimiento menor (retraso en reportes, falta de documentación)	Notificación formal; plazo de 15 días hábiles para subsanar.
Incumplimiento grave (brecha de seguridad no reportada, acceso no autorizado a datos)	Suspensión temporal del servicio; activación del plan de contingencia; evaluación legal.
Incumplimiento reiterado o doloso	Rescisión del contrato; reporte a la Autoridad Nacional de Protección de Datos si corresponde.

1.11. Documentos Relacionados

Código	Nombre
P-SGSI-06	Procedimiento de Gestión de Seguridad con Proveedores
D-SGSI-04	Metodología de Evaluación y Tratamiento de Riesgos
D-SGSI-05	Declaración de Aplicabilidad (SoA)
F-SGSI-01	Formato de Solicitud de Alta/Baja/Cambio de Acceso
POL-SGSI-02	Política de Uso Aceptable, Escritorio y Teletrabajo

1.12. ***